Copilotes IA en environnement industriel

Fiabilité, garde-fous et validation humaine

Auteur : Quentin Bourgois – Version 0.1 (brouillon) – Document de recherche et de réflexion. Il ne décrit aucun résultat mesuré sur un système en production.

> **Convention de lecture.** Les affirmations suivies de [n] sont appuyées par une source listée en fin de document. Les passages marqués **(analyse de l'auteur)** sont des positions argumentées, non des faits sourcés.

---

1. Contexte et question

Un copilote IA industriel est un assistant à base de modèle de langage (LLM) placé à côté d'un système existant : jumeau numérique, historien de données, MES, GMAO. Il répond à des questions, résume des événements, propose des diagnostics ou prépare des actions.

La question de ce document est volontairement étroite : **que peut-on lui déléguer, et à quelles conditions, sans dégrader la sécurité ni la qualité ?**

2. Pourquoi l'industrie est un cas particulier

Un LLM produit des textes fluides, y compris faux. La littérature sur l'hallucination la décrit comme un artefact de la génération neuronale, préoccupant parce que le texte halluciné peut paraître fluide tout en étant infidèle à la source.[1] Cette même revue note que la tolérance à l'hallucination est très faible pour le résumé et la génération à partir de données, car la fidélité à la source y est essentielle.[1]

(analyse de l'auteur) En atelier, la plupart des usages utiles du copilote ressemblent à ces deux tâches : résumer un incident, expliquer une courbe, reformuler une procédure. Ce sont donc des cas où la fidélité à la source compte plus que la fluidité.

3. Les risques à traiter

Trois familles de risques se combinent.

3.1 Erreur du modèle. Hallucination ou confabulation, y compris avec des prompts bénins.[2] L'OWASP traite aussi la désinformation produite par un LLM dans une entrée dédiée (LLM09:2025

Misinformation).[2]

3.2 Manipulation. L'injection de prompt peut modifier le comportement du modèle, même par des contenus non lisibles par un humain, dès lors qu'ils sont traités par le modèle.[2] **(analyse de l'auteur)** Dans un copilote qui lit des documents, des tickets ou des e-mails, tout texte entrant est une surface d'attaque potentielle.

3.3 Autonomie excessive. L'OWASP définit l'*Excessive Agency* comme la vulnérabilité qui permet des actions dommageables en réponse à des sorties inattendues, ambiguës ou manipulées d'un LLM, quelle que soit la cause du dysfonctionnement.[2] Les causes profondes typiques sont trop de fonctions, trop de permissions ou trop d'autonomie.[2]

4. Architecture de garde-fous

Le principe central est de **ne pas confier la décision d'autorisation au modèle**.[2]

L'OWASP recommande notamment :[2]

- de limiter les extensions (outils) au strict nécessaire et de préférer des fonctions granulaires aux fonctions ouvertes (exécuter une commande, récupérer une URL) ;
- de limiter les permissions accordées aux systèmes en aval ;
- d'exiger l'approbation humaine pour les actions à fort impact ;
- d'implémenter l'autorisation dans les systèmes en aval plutôt que de s'en remettre au LLM pour décider si une action est permise.

Elle cite aussi des mesures qui ne préviennent pas le risque mais limitent les dégâts : journalisation, supervision et limitation de débit.[2]

Transposition industrielle (analyse de l'auteur). Je propose de classer les capacités d'un copilote en quatre niveaux, du moins au plus risqué :

1. **Lecture seule** : consulter et expliquer des données.
2. **Préparation** : rédiger un brouillon (ordre de travail, rapport) qui n'a aucun effet tant qu'un humain ne l'a pas validé.
3. **Action réversible validée** : modifier un paramètre non critique avec validation explicite et possibilité d'annulation.
4. **Action sur le procédé ou la sécurité** : hors périmètre du copilote. Elle reste du ressort des automatismes déterministes et des systèmes de sécurité.

Le niveau 4 n'est pas un choix technique du copilote mais une frontière d'architecture.

5. Ancrer les réponses dans les données de l'entreprise

La génération augmentée par récupération (RAG) combine une mémoire paramétrique (le modèle) et une mémoire non paramétrique (un index documentaire) accessible par un récupérateur.[3] Les auteurs de l'article fondateur rappellent que fournir la provenance des décisions et mettre à jour les connaissances restaient des problèmes ouverts pour les modèles purement paramétriques.[3] Ils trouvent aussi que leurs modèles RAG génèrent un langage plus spécifique, plus varié et plus factuel qu'une référence purement paramétrique.[3]

(analyse de l'auteur) Pour un copilote industriel, l'intérêt pratique est d'exiger que chaque réponse cite ses passages sources (procédure, fiche, mesure horodatée). Une réponse sans source est signalée comme telle. Cela ne supprime pas l'hallucination, mais rend l'erreur vérifiable.

6. Validation humaine : exigences de conception

Le règlement européen sur l'IA, pour les systèmes à haut risque, exige qu'ils puissent être effectivement supervisés par des personnes physiques pendant leur utilisation.[4] La supervision doit être proportionnée aux risques, au niveau d'autonomie et au contexte d'usage.[4]

L'article 14 liste ce que les personnes assignées à la supervision doivent pouvoir faire :[4]

- comprendre les capacités et les limites du système et détecter anomalies et dysfonctionnements ;
- rester conscientes du risque de surconfiance dans la sortie (*automation bias*) ;
- interpréter correctement la sortie ;
- décider de ne pas utiliser le système, ou d'ignorer, remplacer ou inverser sa sortie ;
- intervenir ou l'interrompre via un bouton d'arrêt ou une procédure équivalente permettant un arrêt dans un état sûr.

Précision de portée. Ces exigences s'appliquent aux systèmes qualifiés « à haut risque » au sens du règlement. **(analyse de l'auteur, non juridique)** Un copilote de maintenance n'entre pas forcément dans cette catégorie ; la qualification dépend de l'usage (article 6 et annexes du règlement, non analysés ici) et doit être vérifiée cas par cas. Je les utilise ici comme **référence de bonne pratique de conception**, pas comme une affirmation de conformité.

(analyse de l'auteur) Concrètement, une bonne interface de validation affiche la source, le niveau de confiance déclaré, ce que le copilote ne sait pas, et permet de rejeter en un geste.

7. Cybersécurité : où brancher le copilote ?

La série ISA/IEC 62443 définit des exigences et processus pour sécuriser les systèmes d'automatisation et de contrôle industriels (IACS) sur leur cycle de vie.[5] Elle s'appuie sur le découpage en **zones** (groupes d'actifs partageant des exigences de sécurité) et **conduits** (canaux de communication entre zones).[6] La partie 3-2 couvre le partitionnement en zones et conduits, l'évaluation des risques et la fixation d'un niveau de sécurité cible (SL-T) par zone et conduit.[6]

(analyse de l'auteur) Un copilote doit être traité comme un composant à placer dans une zone, avec des conduits explicites vers les autres systèmes, et non comme un utilisateur privilégié qui voit tout. La conséquence directe : le copilote d'analyse reste côté données (jumeau, historien), et aucun conduit ne le relie aux automatismes de commande.

8. Gouvernance et évaluation

Le cadre NIST AI RMF 1.0 organise la gestion du risque IA en quatre fonctions : Govern, Map, Measure, Manage.[7] Il indique que les systèmes d'IA devraient être testés avant déploiement et régulièrement en fonctionnement.[7] Il est d'usage volontaire.[8]

Plan d'évaluation proposé (analyse de l'auteur)

- Un jeu de questions représentatives, avec réponses de référence établies par des experts métier.
- Des mesures séparées : justesse, fidélité aux sources, taux de refus approprié.
- Des tests d'injection avec des documents piégés.
- Un suivi en exploitation : journal des questions, des sources utilisées et des corrections humaines.

9. Cadre de référence : jumeau numérique

La norme ISO 23247 définit un cadre de jumeau numérique pour la fabrication. Sa partie 2 fournit une architecture de référence (vue par domaines et entités, vue fonctionnelle), et sa partie 4 traite des exigences d'échange d'informations entre les entités.[9][10] **(analyse de l'auteur)** Un copilote adossé à un jumeau numérique gagne à s'appuyer sur ce type de modèle commun plutôt que sur des interfaces ad hoc.

10. Limites de ce document

- Il s'appuie sur des textes normatifs et de recherche généraux, pas sur un déploiement mesuré.
- Aucune performance chiffrée n'est revendiquée.
- L'applicabilité juridique du règlement européen à un usage donné n'est pas tranchée ici.
- Les niveaux d'autonomie de la section 4 sont une proposition de l'auteur, non un standard.

- Certains textes cités évoluent (le NIST indique qu'une révision de l'AI RMF est en cours[8]).

11. Conclusion

Un copilote industriel est défendable s'il reste **ancré dans des sources, privé de pouvoir d'action sur le procédé, soumis à une validation humaine réelle et traité comme un composant d'une architecture de sécurité**. La question utile n'est pas « le modèle est-il assez bon ? » mais « que se passe-t-il quand il se trompe ? ».

Sources

1. Ji et al., *Survey of Hallucination in Natural Language Generation*, ACM Computing Surveys / arXiv:2202.03629 – https://arxiv.org/html/2202.03629
2. OWASP, *Top 10 for LLM Applications 2025* (LLM01, LLM06) – https://owasp.github.io/www-project-top-10-for-large-language-model-applications/2_0_vulns/LLM06_ExcessiveAgency.html et https://owasp.github.io/www-project-top-10-for-large-language-model-applications/assets/PDF/OWASP-Top-10-for-LLMs-v2025.pdf
3. Lewis et al., *Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks*, arXiv:2005.11401 – https://arxiv.org/html/2005.11401
4. Règlement (UE) 2024/1689 (AI Act), article 14 « Human oversight » – texte consolidé affiché par le service d'aide de la Commission, non juridiquement contraignant ; la version de référence est celle du Journal officiel de l'UE – https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-14
5. ISA, *ISA/IEC 62443 Series of Standards* – https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards
6. ISAGCA, *Security of Industrial Automation and Control Systems – Quick Start Guide* – https://isasecure.org/hubfs/2023%20ISA%20Website%20Redesigns/ISAGCA/PDFs/ISAGCA%20Quick%20Start%20Guide%20FINAL.pdf ; ANSI/ISA-62443-3-2-2020 (aperçu) – https://www.isa.org/getmedia/661c718f-8e64-446d-acf9-2c6286db1b33/isa-62443-3-2-preview.pdf
7. NIST, *AI RMF 1.0 (NIST AI 100-1)* – https://doi.org/10.6028/NIST.AI.100-1
8. NIST AIRC, *AI RMF* – https://airc.nist.gov/airmf-resources/airmf/
9. ISO 23247-2:2021 – https://www.iso.org/standard/78743.html
10. ISO 23247-4:2021 – https://www.iso.org/standard/78745.html